

Rushing Technologies

ZENFINANCE — SECURITY AUDIT

Security Audit

Last run: July 12, 2026

Dependency Gate

Command:

```
npm audit --audit-level=high
```

Result: passes for high and critical vulnerabilities. `npm audit` still reports moderate advisories in development/tooling dependencies:

- `esbuild` `<=0.24.2` through `drizzle-kit`'s `@esbuild-kit` loader path.
- `uuid` `<11.1.1` through Expo config tooling's `xcode` path.

These are not in the production API request path. Recheck monthly and after new `drizzle-kit` or Expo SDK releases.

Remediations Applied

- Upgraded `drizzle-orm` to clear the server ORM advisory.
- Upgraded `@sentry/node` to the current major and added API event scrubbing before send.
- Upgraded API test/runtime tooling (`vitest` , `tsx`) to remove high/critical audit findings.
- Upgraded the iOS app to Expo SDK 57 with matching React Native, Expo modules, Sentry React Native, and TypeScript versions.
- Added root npm overrides for `tar` and `@xmldom/xmldom` as defense-in-depth if vulnerable transitive paths reappear.

Runtime Hardening

- Sentry payloads are recursively redacted for token, secret, password, Plaid, cookie, authorization, and email-like keys.
- Express central error handling now captures exceptions in Sentry without leaking stack traces to clients.
- Plaid item webhooks explicitly transition items through `active` , `login_required` , and `disconnected` states.
- Account deletion revokes provider items where possible and writes a non-PII deletion audit event.
- Referral premium credits are ledgered separately from RevenueCat entitlements, so promotional access does not overwrite App Store subscription state.

- Public launch insight stats are aggregate-only and suppressed below the minimum linked-user sample size.
- Freelancer Mode routes are premium-gated, store only user-owned settings, and delete profile rows through the user cascade.
- Household Sharing routes expose only household metadata, shared goals, and contributions; linked accounts and transactions stay outside household responses.
- Voice Briefs are generated from already-guarded insight text, run through on-device iOS speech playback, and do not introduce a new external TTS processor.
- Money Physical reports are deterministic server-side summaries from already-owned user data, keyed by RevenueCat non-subscription transaction id, included in export, and deleted through the user cascade.

Required Release Checks

Before external beta or App Store submission:

```
npm run typecheck
DATABASE_URL=postgres://dev:dev@localhost:5434/zenfinance_test npm run test -w @zenfinance/api
npm run build
npm audit --audit-level=high
cd apps/ios && npx expo install --check
```